

SAKURA ROOM

Il mio percorso per completare la storica stanza creata da OSINT Dojo su TryHackMe



ERIKA PELLEGRINO

SEP 08, 2026

Questa non vuole essere l'ennesima guida alla risoluzione della Sakura Room di TryHackMe, una stanza ormai storica, risolta e raccontata da moltissime persone nel corso degli anni. L'obiettivo di questo articolo è diverso: raccontare in modo onesto il percorso di apprendimento fatto attraverso questa stanza, task per task, incluse le difficoltà e soprattutto i concetti che ho imparato grazie a questa sfida.

Nota: nel web si possono trovare molti walkthrough dedicati a questa stanza. Chi desidera cimentarsi nella risoluzione di questa stanza senza spoiler dovrebbe evitare di continuare questa lettura. Se invece si sta cercando un altro lavoro con cui confrontare il proprio, il posto è quello giusto.

TASK 1 - INTRODUCTION

ID: THM-01 SAKURA ROOM (CTF)

ANALISTA: ERIKA PELLEGRINO

DATA ANALISI: 4/09/2026

TARGET: SakuraSnowAngelAiko by OSINT Dojo

OGGETTO ANALISI: Analisi OSINT dell'identità digitale e delle tracce lasciate online da un attaccante fittizio (SakuraSnowAngelAiko), a partire da un'immagine indizio, con l'obiettivo di identificarne username, email, nome reale, wallet crypto, rete Wi-Fi domestica e probabile città di residenza.

METODOLOGIA: SOCMINT, BLOCKINT, GEOINT - ricerca passiva, nessuna interazione diretta con il target

GitHub:

La prima task è puramente introduttiva: Osint Dojo dà il benvenuto nella Sakura Room di TryHackMe. Il testo introduttivo spiega che la stanza è pensata per mettere alla prova una vasta gamma di tecniche OSINT diverse. Ogni sezione presenta alcuni suggerimenti che permettono di raccogliere gli indizi necessari per rispondere alle domande delle task.

Tutte le risposte devono essere ottenute tramite tecniche di ricerca passiva.

TASK 2 - TIP-OFF

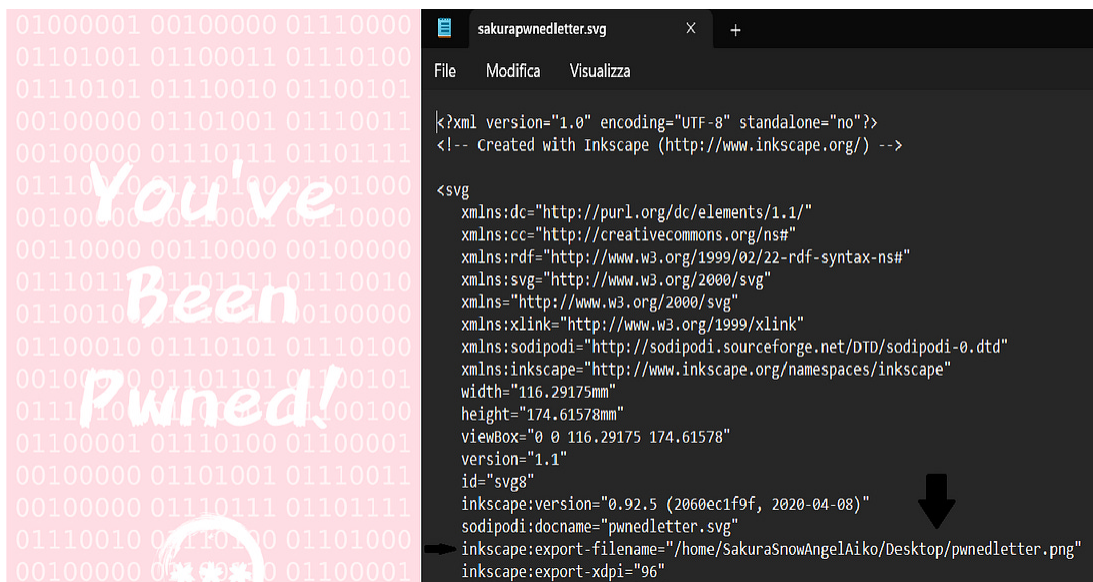
Con la Task 2 inizia davvero la CTF.

Scenario: OSINT Dojo è stato vittima di un attacco informatico. Durante l'indagine forense, gli amministratori del team hanno trovato un indizio lasciato dai criminali informatici: un'immagine (scaricabile). La prima domanda chiede di trovare il nome utente dell'aggressore.

Procedimento:

Con un'immagine come indizio, la prima cosa da fare per ottenere informazioni sarebbe analizzare i metadati, ad esempio con exifeditor.io. Salvando la foto, però, mi accorgo che il formato non era un classico PNG o JPEG, bensì un SVG (Scalable Vector Graphics). Questo formato di immagine non si basa su una griglia di pixel ma su una grafica vettoriale. A differenza delle immagini tradizionali, che contengono una mappa di punti colorati, un file SVG contiene istruzioni matematiche e codice in formato XML (eXtensible Markup Language). Un XML è un formato di testo progettato per memorizzare, organizzare e trasportare dati in un modo comprensibile sia dalle persone che dalle macchine.

Per ottenere più informazioni su un'immagine in formato SVG è sufficiente salvarla e aprirla con un editor di testo (Blocco Note, Visual Studio Code ecc.) invece che con un visualizzatore di immagini. Così facendo appare il codice sorgente completo.



Indizio immagine e codice sorgente

Leggendo il codice sorgente ho la risposta alla prima domanda: il nome dell'attaccante è *SakuraSnowAngelAiko*, riportato nella directory personale dell'attaccante in cui era stata salvata la foto. Il formato `/home/nomeutente/Desktop/...` è tipico dei sistemi Linux.

Cosa ho imparato:

- che cos'è una immagine SVG e la differenza con i formati di immagine più tradizionali; l'importanza analitica del codice sorgente in un'indagine.

TASK 3 - RECONNAISSANCE

Avere uno username è un buon punto di partenza per trovare ulteriori informazioni. La Task 3 ricorda che spesso le persone riutilizzano lo stesso nome utente su più piattaforme, quindi è probabile che lo stesso username venga usato per iscriversi ad altri servizi web come, ad esempio, i social network. La stanza consiglia di cercare username corrispondenti al target trovato su altre piattaforme, facendo però attenzione ai falsi positivi.

Le risposte da trovare in questa task sono due: l'indirizzo email dell'attaccante e il suo nome completo.

Procedimento:

Per trovare le piattaforme social collegate allo username esistono diversi metodi: Google Dorking, tools come Sherlock o Maignet oppure strumenti disponibili sul web come WhatsMyName. Per questo esercizio ho scelto quest'ultimo, considerato uno dei tool più affidabili e attivi in ambito OSINT.

Inserendo lo username *SakuraSnowAngelAiko* nella barra di ricerca del tool, ho ottenuto una serie di risultati segnalati con tre colori - verde, giallo, rosso - dal più affidabile al più probabile falso positivo fino al non trovato. L'unico risultato sicuro è risultato essere un profilo GitHub.

Category Filters

Active Filter: All (exclude NSFW)

Found: 1 Processed: 677 / 677

Show Found Show False Positives Show Not Found Show All Open All Links

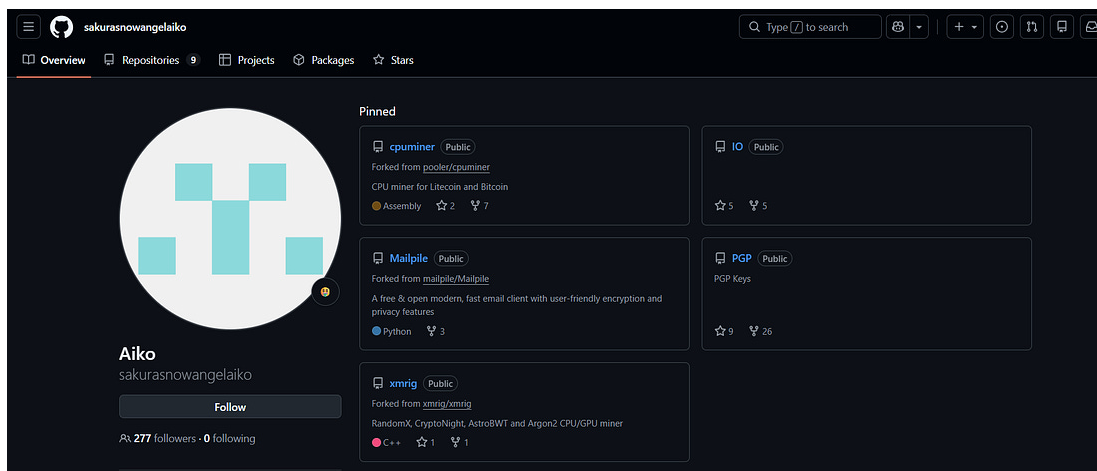
SITE	USERNAME	CATEGORY	LINK
GitHub (User)	SakuraSnowAngelAiko	coding	https://github.com/SakuraSnowAngelAiko

Risultati WhatsMyName

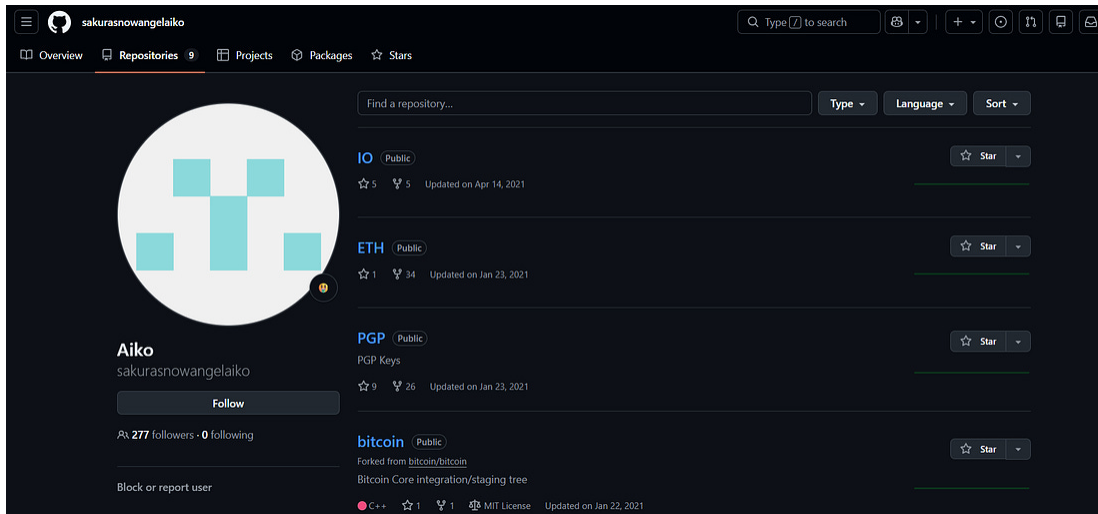
Per scrupolo e per apprendimento, ho controllato velocemente anche i risultati evidenziati in giallo, cioè i "potenziali" falsi positivi. Tutte queste pagine si sono rivelate inesistenti (errore 404) o non pertinenti allo scopo della ricerca. Riguardo ai falsi positivi è necessario sapere che, quando si cerca uno username, molti siti in cui questo non è esistente,

non danno come risultato un errore chiaro come “404 - not found” ma mostrano comunque una pagina generica con codice di risposta “200 ok” che, di norma, indica “pagina trovata correttamente”. Uno strumento automatico come WhatsMyName, che si basa solo sul codice di risposta HTTP, non può quindi fidarsi al 100% di questi siti specifici e quindi li marca come “potenziale falso positivo” invece che con “trovato”. Come sto imparando, è buona pratica non lasciare niente al caso ma è altrettanto importante non farsi assorbire troppo da ogni minimo dettaglio quando l'evidenza (in questo caso pagine vuote o non pertinenti) è già abbastanza chiara.

A questo punto ho aperto il profilo GitHub. L'handle della pagina principale corrisponde. il nome visualizzato è *Aiko*. In evidenza ci sono 5 repository, di cui 2 dell'utente e 3 fork. In totale i repo sono 9.



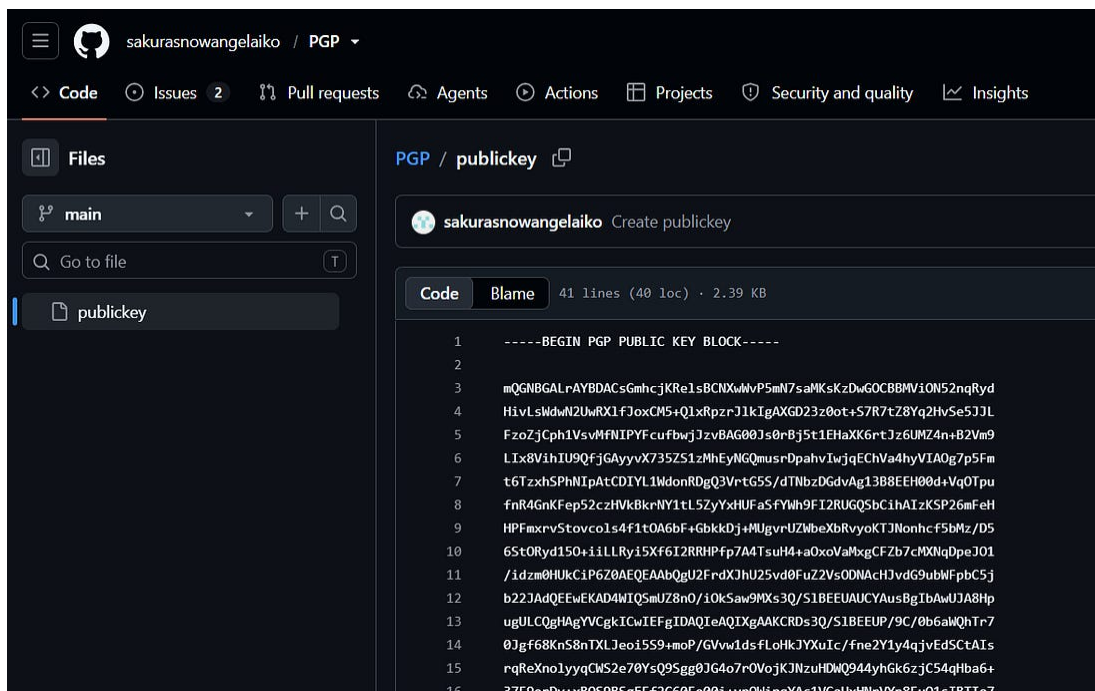
Panoramica profilo GitHub



Repository pubbliche Aiko

Ho quindi cercato indizi tra i vari repository. Il repo “IO” non sembra contenere indizi utili. Ho aperto poi il repo “ETH”, che contiene il file “miningscript” al cui interno è contenuto il primo indizio: un URL di connessione (stratum) verso un pool di mining che include, tra l’altro, un indirizzo di tipo ETH wallet.

Una volta salvato questo indizio ho continuato ad aprire i repo. La terza è il repository “PGP” che contiene un altro indizio: una chiave pubblica codificata in Base64, un formato utilizzato per rappresentare dati binari come testo.



The screenshot shows a GitHub repository interface for a user named 'sakurasnowangelaiko'. The repository is named 'PGP'. The file 'publickey' is selected in the 'Files' sidebar. The main content area displays the code for 'publickey', which is a PGP public key block in Base64 encoding. The code starts with '-----BEGIN PGP PUBLIC KEY BLOCK-----' and ends with '37F9erDv+xxR0S9B5eFEf2C60Fe00i+yp0WipnYAc1VGaUxhNpVyn8Fu01sTRIto7'. The file is 41 lines long, 40 loc, and 2.39 KB.

Public Key Base64 nella Repo PGP

Considerando la priorità e l'obiettivo della Task 3, il primo passo da fare è stato decodificare la chiave pubblica. Per farlo ho utilizzato GPG Decoder, uno strumento web gratuito pensato proprio per “aprire” una chiave PGP (Pretty Good Privacy), estrarre il suo contenuto e mostrarlo in linguaggio umano. La chiave PGP è in realtà composta da una chiave pubblica e una chiave privata. La chiave pubblica è un valore numerico che può essere condiviso con chiunque per poter mandare messaggi crittografati o verificare firme digitali. Chiunque voglia conoscere il contenuto deve utilizzare questa chiave per decifrare i dati. La chiave privata invece è custodita dal proprietario e non va divulgata. Serve esclusivamente a decrittografare i messaggi ricevuti o generare firme digitali. È una crittografia asimmetrica: un messaggio inviato utilizzando la chiave pubblica del destinatario può essere letto solo da chi possiede la corrispondente chiave privata.

```
b4 20 53 61 6b 75 72 61 53 6e 6f 77 41 6e 67 65 User ID Packet (0xd)
6c 38 33 40 70 72 6f 74 6f 6e 6d 61 69 6c 2e 63
6f 6d
cipherTypeByte: "180"
length: "32"
userId: "SakuraSnowAngel83@protonmail.com"
```

Decodifica Public Key

La decodifica mostra la soluzione alla prima domanda della Task 3, cioè l'indirizzo email dell'attaccante: *SakuraSnowAngel83@protonmail.com*.

Ottenuta questa email ho provato diverse strade per sfruttarla e trovare la risposta alla seconda domanda della Task 3, cioè trovare il nome completo dell'attaccante. Ho utilizzato vari dork di Google, più o meno rigidi, senza ottenere risultati utili. Quasi per caso, ho provato a cercare su Google l'intero nome *SakuraSnowAngelAiko* ma scritto separato in linguaggio naturale: *Sakura Snow Angel Aiko*. Solo così sono riuscita a trovare una Pagina X (Twitter) di Aiko.

NOTA: avendo già svolto l'esercizio self-made SOCMINT-01 con questo stesso account come target ("Username Enumeration, Cross-Platform Correlation e Manual Verification: caso studio SOCMINT", consultabile su questo profilo), sapevo che quella pagina esisteva, eppure non sono riuscita a trovarla con dork specifici e rigidi (virgolette, operatori site:); è stata una ricerca testuale meno vincolata a farla emergere.



← Aiko
8 posts



Aiko
@SakuraLoveAiko

📅 Qui da giorno gennaio 2021

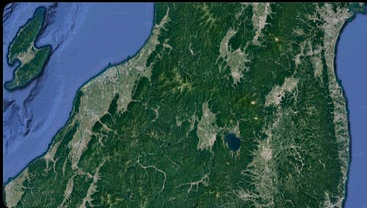
1 Following 200 Follower

Menziona Segui

Post Risposte Repost Contenuti

Aiko @SakuraLoveAiko · 30 gen 2021
Silly me, I forgot to introduce myself!
Hi there! I'm @AikoAbe3!
🗨️ 🔄 ❤️ 23 📌 📤

Aiko @SakuraLoveAiko · 26 gen 2021
Questo post proviene da un account sospeso. Scopri di più
🗨️ 🔄 ❤️ 7 📌 📤

Aiko @SakuraLoveAiko · 25 gen 2021
Sooo close to home! Can't wait to finally be back :)

🗨️ 🔄 ❤️ 27 📌 📤

Aiko @SakuraLoveAiko · 25 gen 2021
My final layover, time to relax!

🗨️ 🔄 ❤️ 17 📌 📤

Aiko @SakuraLoveAiko · 24 gen 2021
Checking out some last minute cherry blossoms before heading home!

🗨️ 🔄 8 ❤️ 62 📌 📤

Accedi o iscriviti a X

Guarda che c'è di nuovo e partecipa alla conversazione.

📱 Continue with phone

oppure

📧 Accedi con nome utente o email

Termini · Privacy · Cookie · Accessibilità ·

Info sugli annunci · Altro — © 2026 X Corp.

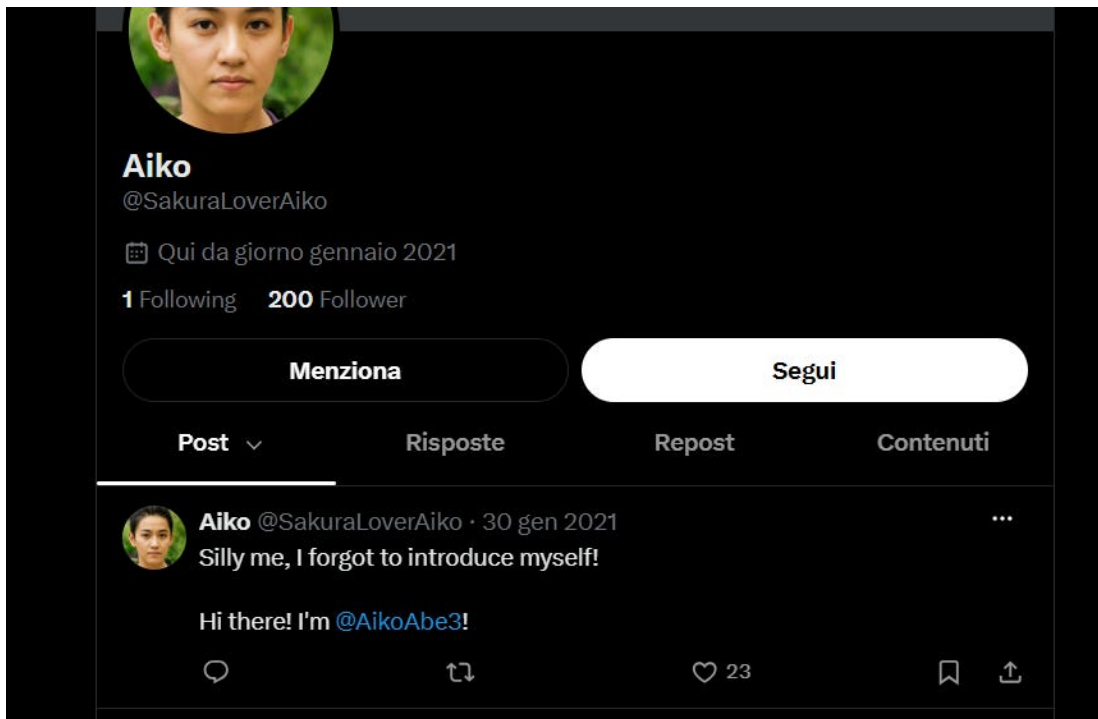
Scansiona per ottenere l'app





Profilo X di Aiko

Proprio il primo tweet ha dato la risposta alla seconda domanda della Task 3: *Aiko Abe*.



Tweet I'm AikoAbe3

Conclusa la Task 3, mi sono fermata un attimo a guardare il profilo X di Aiko con attenzione, annotando su Obsidian quello che vedevo:

- un tweet in cui si presenta come “@AikoAbe3”
- un post apparso come sospeso/rimosso
- un immagine satellitare di una regione
- un’immagine in cui dice che sta facendo il suo ultimo scalo prima di tornare a casa

- un'immagine con un albero di ciliegio su un lungo viale in cui dice si essersi fermata ad ammirarlo prima del check-out e di tornare a casa

Cosa ho imparato:

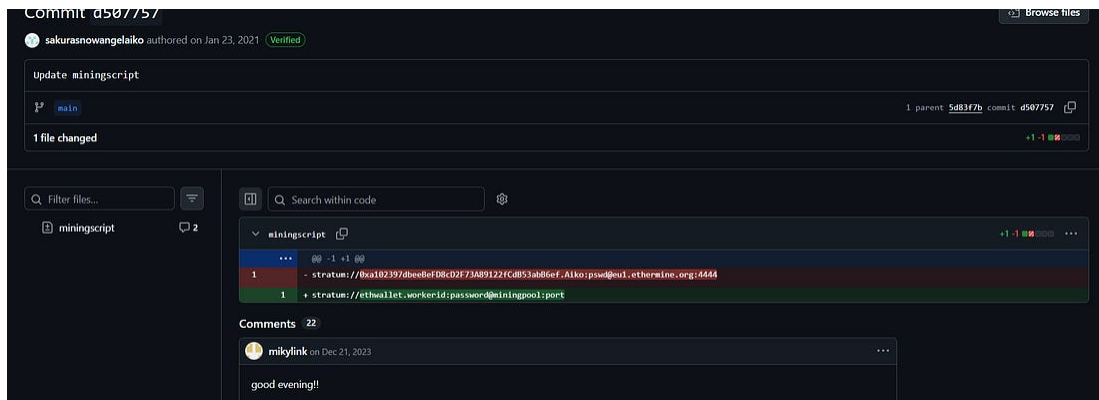
Fare attenzione ai falsi positivi e saper valutare cosa approfondire e cosa no; come si può decodificare una chiave pubblica e quanto può essere ricca di informazioni; come un dork troppo rigido può fallire dove un ricerca testuale più naturale riesce, quindi vale sempre la pena provare entrambi gli approcci prima di considerare una pista esaurita.

TASK 4 - UNVEIL

Nella Task 4 i suggerimenti fanno riferimento alla cronologia (history) dei commit dei repository di GitHub, mentre le domande riguardano il mondo delle criptovalute. Era chiaro che le risposte fossero collegate all'indizio "stratum" trovato in precedenza nel repo ETH.

Procedimento:

Sono tornata nel repo ETH e ho guardato meglio la history dei commit dove avevo già individuato l'indirizzo del wallet. Nella cronologia era presente un primo commit, in cui viene mostrato apertamente l'indirizzo del wallet. Anche se il file era stato successivamente modificato per ripulire i dati sensibili palesati, il principio di immutabilità della cronologia di GitHub ha reso comunque possibile recuperare la versione originale.



History di miningscript e indirizzo wallet ETH

Come si vede il commit originale riporta l'indirizzo wallet:

0xa102397dbeebf8cD2F73A89122fCdB53abB6ef.

Un URL in formato Stratum è lo standard con cui un miner (cioè un individuo o entità che mette a disposizione il proprio computer per il mining, cioè il processo con cui si creano nuove crypto e le transazioni vengono verificate e aggiunte alla blockchain), si connette o si “presenta” ad un pool di mining per ricevere ricompense in criptovaluta. È come una consegna a domicilio: prima di ricevere qualcosa bisogna dire con precisione dove recapitarla, chi sta ordinando e da dove. La struttura generale stratum://[indirizzo_wallet].[worker_id]:[password]@[server_del_pool]:[porta] mostra ogni componente che identifica un pezzo della configurazione:

- l'indirizzo wallet è l'indirizzo di consegna → qui è dove arrivano le ricompense, un errore qui significa che qualcun altro riceverà la ricompensa;
- il worker ID è come il nome scritto sul citofono → utile se ci sono più dispositivi che lavorano contemporaneamente sullo stesso wallet perché permette di distinguere chi effettivamente sta producendo cosa;
- la password serve solo per confermare l'ordine;

- server e porta sono l'indirizzo del negozio a cui ci si collega per fare l'ordine → cioè il pool di mining stesso.

Con questo indizio è stato possibile rispondere alla prima domanda della task: la criptovaluta del wallet dell'aggressore è Ethereum (ETH). La seconda domanda chiedeva quale fosse l'indirizzo del wallet cioè lo stesso indirizzo recuperato dal commit cancellato riportato sopra.

La terza domanda è più specifica: chiede da quale mining pool l'aggressore ha ricevuto pagamenti nella data del 23 gennaio 2021. La data del commit GitHub coincide. Per approfondire e trovare la risposta a questa domanda ho usato Etherscan.

Etherscan è un block explorer, cioè un motore di ricerca che permette di consultare in tempo reale la blockchain di Ethereum. La sua interfaccia rende leggibili i dati che altrimenti esisterebbero solo come flusso di dati grezzi distribuiti su migliaia di nodi nel mondo. Questo strumento serve per consultare indirizzi, transazioni, smart contract e tanto altro. Inserendo l'indirizzo del wallet su Etherscan, la panoramica della pagina mostra alcune informazioni chiave sull'indirizzo: il saldo attuale in ETH e il suo controvalore in dollari, tag associate all'indirizzo, la data della prima e dell'ultima transazione effettuata e l'indirizzo che lo ha finanziato per la prima volta (funded by); più sotto una tabella elenca cronologicamente le transazioni effettuate dall'indirizzo con hash, mittente, destinatario, importo e commissione (gas fee) di ciascuna.

The screenshot shows the Etherscan interface for the address 0xa102397dbefB8cD2F73A89122CdB53abB6ef. The top navigation bar includes links for Home, Blockchain, Tokens, NFTs, Resources, API, and Sign In. The address bar shows the address and buttons for Buy, Prediction, Play, and Gaming. The main content area is divided into three sections: Overview, More Info, and Multichain Info. The Overview section displays the ETH balance (0.000232149448528985 ETH) and the ETH value (\$0.57). The More Info section shows the private name tags, transactions sent (latest: 2 yrs 73 days ago), and the funded by address (0xB256cae2_E2d6d2344). The Multichain Info section shows the multichain portfolio (ETH, Multichain Portfolio) and a note that no addresses were found. Below the sections is a tabbed interface for Transactions, Internal Transactions, Token Transfers (ERC-20), Other Transactions, Analytics, Assets, and Cards. The Transactions tab is selected, showing a list of transactions with columns for Transaction Hash, Method, Block, Age, From, To, Amount, and Txn Fee. The list shows the latest 25 transactions out of a total of 42.

Overview indirizzo ETH

In questo caso, l'indirizzo aveva un totale di 42 transazioni. Era necessario individuare quella avvenuta il 23 gennaio 2021. Facendo un calcolo approssimativo, si trattava di circa 2050 giorni prima della data corrente. Scorrendo la lista delle transazioni ho raggiunto quella fascia di giorni e passando il cursore sopra il campo "Age" di ciascuna transazione che si avvicinava a quel numero ho potuto leggere la data/ora esatta e individuare quella avvenuta il 23 gennaio 2021.

0x431503d5c7...	Transfer	11732875	2047 days ago 2021-01-23 20:30:43	Ethermine	IN	0xa102397d...B53abB6ef	0.050069945 ETH	0.000021
0xde6b72f4ee8...	Transfer	11714008	2049 days ago	Ethermine	IN	0xa102397d...B53abB6ef	0.050073325 ETH	0.000021

Transazione 23 Gennaio 2021

Così facendo ho potuto rispondere alla terza domanda. Il mining pool da cui l'aggressore ha ricevuto pagamenti in quella data è *Ethermine* (colonna "from").

L'ultima domanda della Task 4 chiede con quale altra criptovaluta l'aggressore ha effettuato uno scambio utilizzando il proprio wallet. Su Etherscan, nella pagina di un indirizzo, sono disponibili diverse schede (tab) oltre a quella predefinita "transaction"; tra queste c'è anche "Token Transfers (ERC-20)" che mostra unicamente i movimenti di token diversi dall'ETH nativo effettuati da quell'indirizzo.

Transactions	Internal Transactions	Token Transfers (ERC-20)	Other Transactions	Analytics	Assets	Cards	Advanced Filter
Latest 10 ERC-20 Token Transfer Events							Download Page Data
Transaction Hash	Method	Block	Age	From	To	Amount	Token
0x6559fcc264a...	Transfer	11686873	2054 days ago	0xa102397d...B53abB6ef	OUT 0xE5f4990e...D2f600AcA	2,595	Tether USD (USDT)
0x6006d4d6aa...	Transfer	11684494	2055 days ago	Binance 3	IN 0xa102397d...B53abB6ef	2,595	Tether USD (USDT)
0xc057104cc5...	Transfer	11678837	2056 days ago	0xa102397d...B53abB6ef	OUT 0xE5f4990e...D2f600AcA	4,195	Tether USD (USDT)
0x4c12535cbe...	Transfer	11667369	2057 days ago	Binance 2	IN 0xa102397d...B53abB6ef	4,195	Tether USD (USDT)

Tab Token Transfers (ERC-20)

Nell'immagine si può vedere che l'altra valuta utilizzata dall'aggressore è *Tether*.

Cosa ho imparato:

Questa task mi ha permesso di imparare le basi sul mondo delle blockchain e delle criptovalute: come leggere una pagina Etherscan; come avviene una transazione e i vari elementi necessari ad attuarla.

TASK 5 - TAUNT

Nella Task 5 il focus torna sull'account X di cui avevo già salvato l'intera pagina e i dettagli in precedenza. I suggerimenti di questa task fanno riferimento allo screenshot di un messaggio dell'aggressore inviato a OSINT Dojo su Twitter e suggeriscono anche di seguire i fili (lead) dell'account verso il Dark Web.

Procedimento:

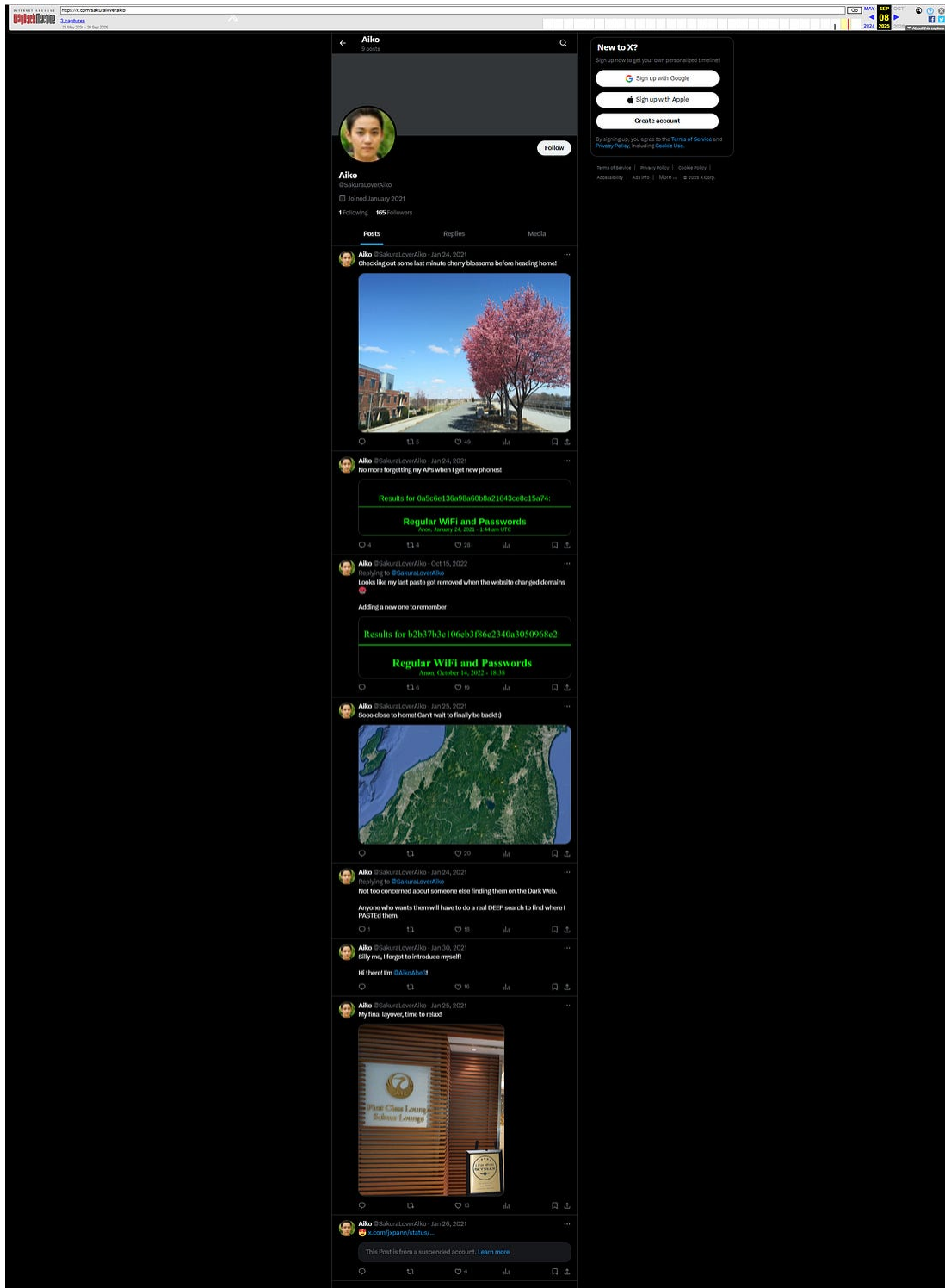
Rispondere alla prima domanda della task 5 è stato facile. Chiedeva semplicemente quale fosse l'handle del profilo, cioè: *SakuraLoveAiko*.

La seconda domanda della task chiedeva invece quale fosse il BSSID del Wi-Fi domestico dell'aggressore. Il BSSID (Basic Service Set Identifier) è l'indirizzo fisico univoco di un access point - il dispositivo (router o ripetitore) che trasmette il segnale Wi-Fi.

Qui è importante conoscere una distinzione fondamentale tra il BSSID e il SSID. L'SSID è il nome della rete Wi-Fi: quello scelto liberamente configurando il router (es. casa1234) e che può essere cambiato quando si vuole. Il BSSID è invece l'indirizzo fisico del dispositivo che trasmette quella rete. È come se fosse l'indirizzo civico univoco di quel dispositivo ed è legato all'hardware specifico non alla volontà dell'utente.

Questa distinzione conta per un'indagine perché due persone potrebbero chiamare la propria rete Wi-Fi allo stesso modo (stesso SSID), ma avranno sempre un BSSID diverso perché sono router fisici diversi. Il BSSID è geolocalizzabile tramite database come WiGLE costruiti da community di persone che mappano fisicamente le reti WiFi per strada (pratica chiamata wardriving). Se un router di una persona è mai stato avvistato da un wardriver, il suo BSSID risulta associato a coordinate GPS precise, permettendo di risalire a dove si trova fisicamente quella rete e quindi, molto probabilmente, a dove vive o lavora quella persona.

Ritornando alla Task 5, mi sono resa conto che il post apparso come sospeso su X, annotato nelle osservazioni precedenti, probabilmente conteneva l'indizio necessario per rispondere a questa domanda. L'unico modo per vederne il contenuto era consultare una versione archiviata del profilo precedente alla sospensione del tweet. Ho quindi utilizzato Wayback Machine e sono fortunatamente riuscita a trovare una copia archiviata risalente al 2025.



Account X di Aiko archiviato su web.archive.org

Il post recuperato conteneva le informazioni mancanti: un elenco di Wi-Fi e relative password in cui la stringa alfanumerica visibile era un hash,

cioè il risultato di una funzione matematica che prende un contenuto (testo, file, immagine) e lo trasforma in una stringa di lunghezza fissa univoca e identificativa, come se fosse un'impronta digitale: anche una minima modifica al contenuto originale cambia completamente l'hash risultante. Questa stessa identica funzionalità - testo pubblico accessibile con un link senza bisogno di registrazione o identificazione - diventa comoda anche per chi vuole condividere qualcosa senza lasciare tracce dirette collegate alla propria identità reale e quindi per usi eventualmente illegittimi.

Nel profilo X di Aiko si vede anche un commento dell'attaccante: *"Not too concerned about someone else finding them in the Dark web. Anyone who wants them will have to do a real DEEP search to find where I PASTEd them"*. Il gioco di parole è deliberato ed è un altro indizio per risolvere l'ultima domanda di questa task, cioè qual è il BSSID.

La parola DEEP e la parola PASTE(d) scritte in maiuscolo enfatizzano il gioco di parole che, collegato al suggerimento di cercare nel dark web, fanno pensare che forse c'è un servizio come Pastebin anche nel dark web e che magari si chiama DEEP PASTE. DeepPaste funziona sullo stesso principio di Pastebin: un link univoco per recuperare un contenuto senza registrazione, con la differenza che l'identificatore usato qui è un hash, anziché un ID casuale come nel caso dell'applicazione Pastebin. A questo punto dell'esercizio ho avuto le più grosse difficoltà e ho scoperto e imparato anche tantissime cose su queste applicazioni di text hosting e sul dark web. Ho scaricato sulla mia Virtual Machine e usato per la prima volta Tor browser e motori di ricerca come Ahmia e Torch. Ho scoperto che cercare qualcosa nel dark web è molto diverso dal cercare qualcosa sul clear web e che i siti spariscono da un giorno all'altro ma vengono anche creati dei sostituti ancora più velocemente. Lo scopo di entrare nel dark web per questa task era trovare Deep Paste per poter ricavare le informazioni necessarie dall'hash esposto da Aiko e quindi avere la risposta oppure altri indizi che potessero servirmi per concludere la task 5; tuttavia

dopo un po' (tanto) di studio e dopo tante prove e tante ricerche mi sono fermata. Forse potrei essere io non ancora capace ma, da quanto ho capito, è molto probabile che il sito Deep Paste non sia più raggiungibile. Anche trovando un servizio di paste funzionante e attivo oggi, questo non servirebbe a recuperare il contenuto specifico che l'attaccante aveva salvato nel 2021 su Deep Paste perché l'hash esposto nel tweet è legato ESCLUSIVAMENTE al database Deep Paste: un servizio diverso, ha un database completamente diverso.

Non essendo riuscita a verificare personalmente il contenuto originale su Deep Paste, ho ottenuto il valore SSID necessario e gli altri indizi da un walkthrough pubblicato online: un'informazione di seconda mano che ho comunque confermato personalmente in modo indipendente con una ricerca su WiGLE. Il nome della rete, cioè l'SSID è: DK1F-G. Fra i risultati c'erano altri Wi-Fi con relative password salvate nella lista con lo scopo di non dimenticarle; fra queste c'era anche il Wi-Fi pubblico della città di Hirosaki, Giappone.

DeepPaste

Your Deep-Shit Hoster for special shit

Results for 0a5c6e136a98a60b8a21643ce8c15a74:

Regular WiFi and Passwords

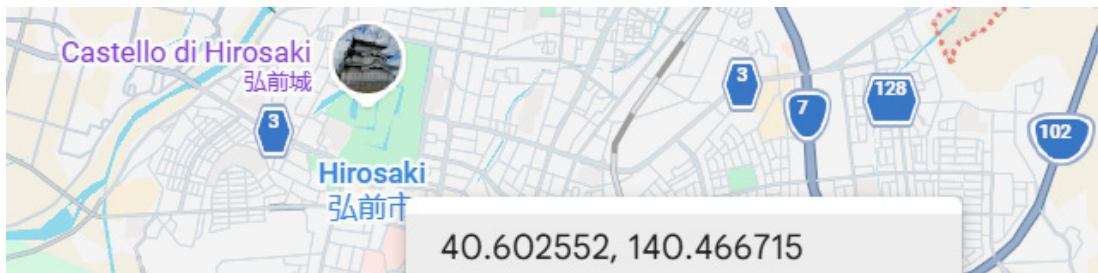
Anon, January 24, 2021 - 1:44 am UTC

```
Saving here so I do not forget

School WiFi Computer Lab:      GTRI-Device      GTgftttt4422!@
McDonalds:                     Buffalo-G-19D0~1  Macdonalds2020
School WiFi:                   GTvisitor        GTFree123
City Free WiFi:                HIROSAKI_Free_Wi-Fi  H_Free934!
Home WiFi:                     DK1F-G           FsdF324T@@
```

Con questi indizi sono riuscita ad andare avanti.

Su WiGLE la pagina advanced research permette di inserire diversi dati per risalire ad altri ancora. WiGLE non cerca un punto geografico esatto (sarebbe troppo restrittivo), ma cerca dentro un rettangolo geografico, cioè un intervallo di latitudine e longitudine. Una volta imparato questo ho fatto una prova. Ho cercato su Google Maps la città di Hirosaki per ricavare le coordinate e affinare la ricerca sul database.



coordinate città di Hirosaki, Japan

Inserendo l'SSID (DK1F-G) insieme ad un intervallo di coordinate che copre l'area di Hirosaki su WiGLE, la ricerca ha restituito il risultato che cercavo, cioè il BSSID → *84:af:ec:34:fc:f8*.

Per curiosità ho verificato se il filtro geografico fosse davvero necessario per trovare il BSSID o se il SSID fosse sufficiente da solo a isolare un risultato univoco. Ho ripetuto la stessa ricerca lasciando i campi della longitudine e latitudine vuoti e il risultato è stato lo stesso. Questo può succedere quando il SSID, cioè il nome che si dà al proprio Wi-Fi, è davvero originale e unico. Tuttavia, il BSSID è il dato davvero utile per una geolocalizzazione fisica.

Cosa ho imparato:

Con questa task ho fatto la mia prima ricerca sul dark web e imparato molte cose a riguardo, soprattutto come fare ricerche su questa rete; le

varie tipologie di hash e i loro usi (lo SHA-256 l'ho già usato per validare le prove in altri esercizi) e a cosa servono i servizi paste; ho imparato la differenza fra SSID e BSSID e come si geolocalizza un router.

TASK 6 - HOMEBOUND

Nell'ultima Task della stanza, la numero 6, il suggerimento iniziale racchiude un grande insegnamento: in OSINT, spesso non esiste una "pistola fumante" che indichi una risposta chiara e definitiva. Un analista OSINT deve invece imparare a sintetizzare più informazioni per trarre una conclusione su ciò che è probabile, improbabile o possibile.

Procedimento:

Per concludere la stanza è stato necessario sfruttare tutti i dati disponibili e le informazioni acquisite in precedenza per rintracciare l'aggressore e, in particolare, il luogo in cui abita. Le domande della Task 6, fanno riferimento in modo specifico ai tweet che l'attaccante aveva postato - già annotati in precedenza - per scoprire il nome dell'aeroporto di partenza, quello dell'ultimo scalo prima di arrivare a destinazione, il nome del lago presente al centro della foto fatta dall'alto e postata sull'account, e infine qual è probabilmente la città natale dell'aggressore.

La prima domanda chiede quale sia l'aeroporto più vicino al luogo in cui l'aggressore ha condiviso una foto prima di partire.

Prima di partire, Aiko aveva pubblicato un tweet con la seguente foto.



Nella foto si vedono alcuni alberi di ciliegio lungo il viale a destra; un passaggio (forse pedonale) con delle barriere di sicurezza sul bordo; alcuni edifici a sinistra; un ampio spazio verde, forse un campo da gioco, più avanti sulla sinistra; e, sullo sfondo, una struttura molto alta di colore bianco, dalla forma simile ad una torre. È stato chiaro fin da subito che quest'ultima struttura fosse l'indizio principale. Prima però ho provato a cercare l'immagine per intero, senza tagliare sulla torre, tramite Google Image Search, ma le uniche corrispondenze trovate erano i post di Aiko e le soluzioni della room pubblicate negli anni. Ho provato anche con Yandex ma stessa cosa.

Questo tentativo iniziale mi ha fatto capire quanto sia importante analizzare ogni dettaglio di una immagine in modo minuzioso, per condurre una ricerca che non solo dia risultati concreti, ma che sia anche più mirata e affidabile.

Ho quindi zoomato l'immagine e ritagliato il dettaglio della torre (nonostante la risoluzione non fosse ottimale), per condurre un test usando l'estensione Search by Image su Brave, che permette di cercare un'immagine su più motori di ricerca contemporaneamente.

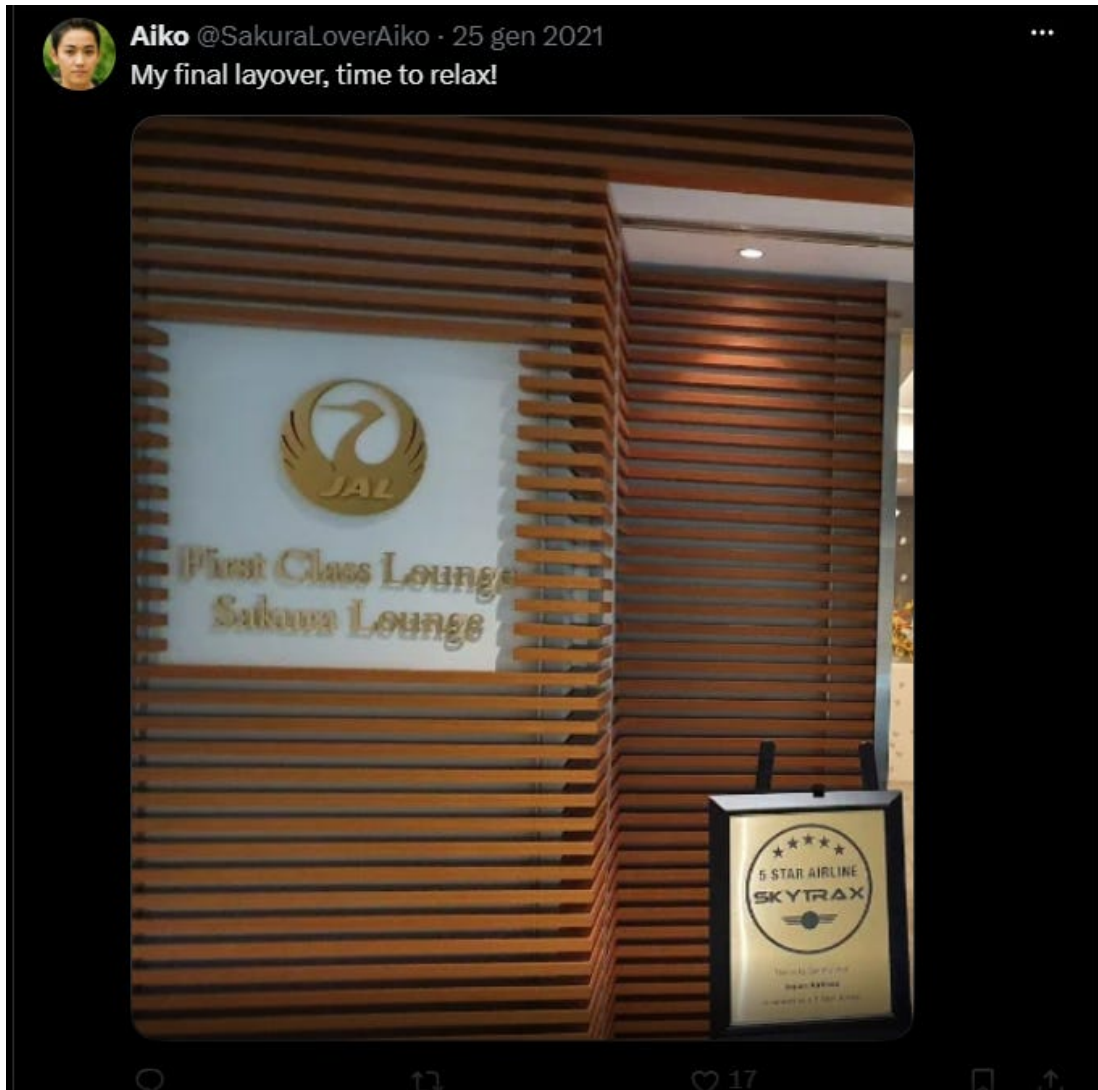


Dettaglio torre con risoluzione bassissima

Ho avviato la ricerca su numerosi motori - Google, Yandex, TinEye, Baidu e altri - ma l'unico a trovare una corrispondenza esatta in questo caso è stato Google. La torre in questione è il Washington Monument (Washington, D.C., USA). In seguito, con una semplice ricerca su Google, ho scoperto che l'aeroporto più vicino all'obelisco è l'Aeroporto Nazionale di Washington-Ronald Reagan (DCA), situato ad Arlington (Virginia) a circa 6km dal monumento, confermato da Google Maps. La sigla di questo aeroporto (*DCA*) è la risposta alla prima domanda.

Per scoprire in quale aeroporto l'aggressore ha fatto l'ultimo scalo, è stato utile un altro post di Aiko, in cui dichiara esplicitamente che si

tratta del suo ultimo scalo.



La foto mostra diversi dettagli: in primo piano la scritta “5 Star Airline Skytrax”. Con una semplice ricerca ho scoperto che si tratta di un prestigioso titolo riconosciuto dall’agenzia di rating britannica Skytrax, assegnato a chi raggiunge un alta qualità in servizi e prodotti in aeroporto e a bordo. L’elegante cartello affisso sulla parete indica inoltre che si trova nella lounge dell’aeroporto.

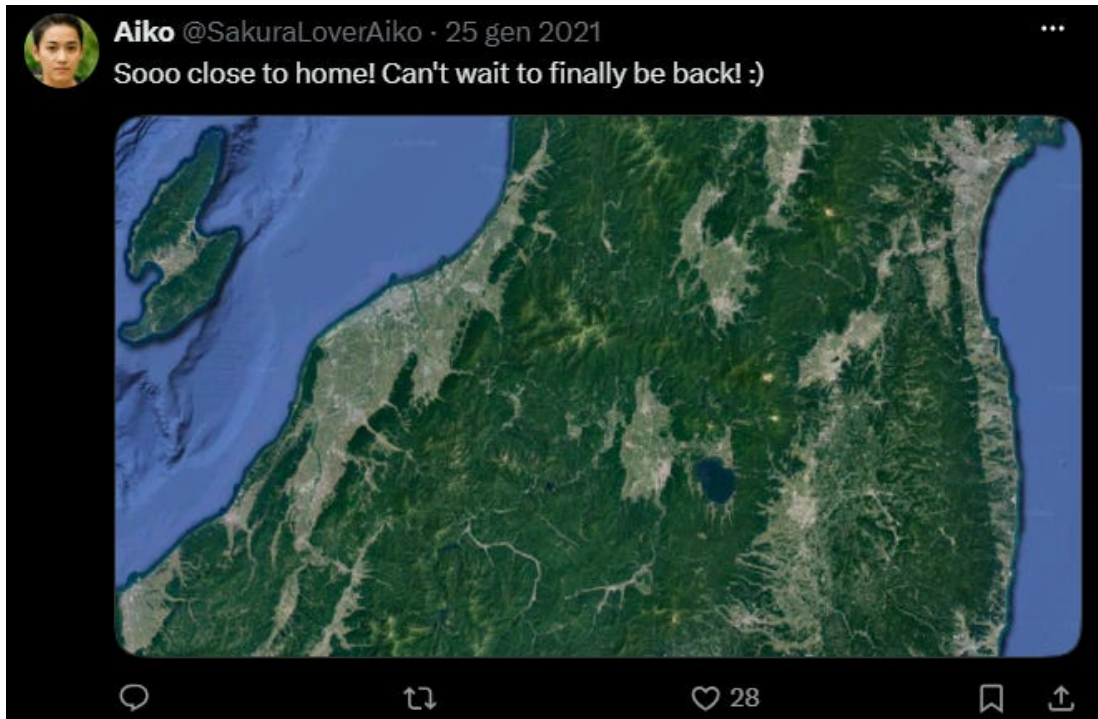
Anche in questo caso ho utilizzato Reverse Image Search di Google. La ricerca ha restituito questa volta risultati pertinenti, oltre ovviamente a

quelli legati alla sfida stessa. L'IA mi aveva già dato subito la risposta ma in un'indagine reale è importante verificare la fonte. Da queste immagini ho scoperto che la lounge appartiene a Japan Airlines First Class e controllando i risultati pertinenti emerge che si tratta precisamente della lounge dell'aeroporto di Tokio Haneda, la cui sigla è la risposta alla seconda domanda: *HND*.



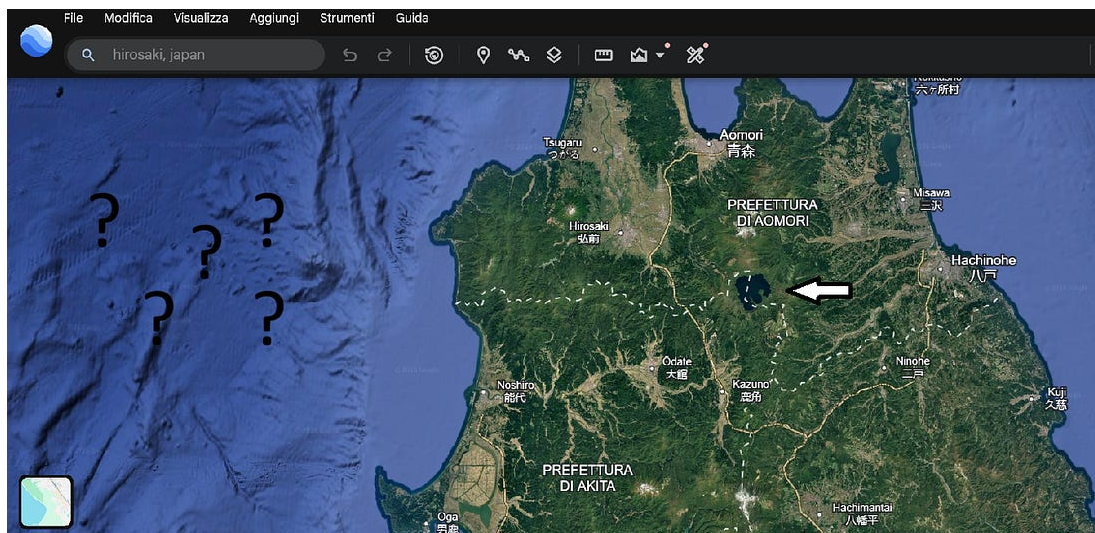
Risultati ricerca lounge aeroporto

La terza domanda della Task 6 chiede quale sia il lago che appare nella foto dall'alto pubblicata da Aiko.



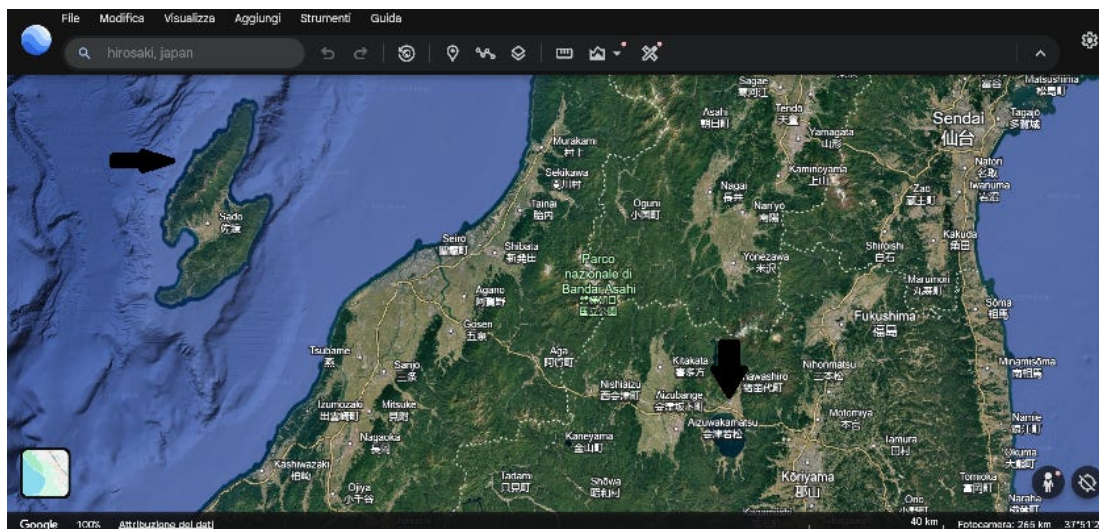
Il lago è ben visibile nella foto, centrato leggermente a destra; sulla sinistra è presente invece un'isola dalla forma molto particolare. Considerando gli altri indizi raccolti fino a questo momento - lo scalo a Tokio e il riferimento a Hirosaki emerso dal nome della rete Wi-Fi nella task precedente - si ha ormai una ragionevole certezza che l'immagine rappresenti una porzione del Giappone.

Ho quindi utilizzato Google Earth, che offre una visibilità molto dettagliata, cercando "Hirosaki, Japan". L'immagine mostrava effettivamente un lago dalla forma simile a quello del tweet: il lago Towada. Tuttavia, l'isola dalla forma strana presente sulla sinistra non compariva in quell'area.



Lago Towada

Ho quindi allargato la visuale per trovare quell'isola. L'isola dalla forma inconfondibile è quella di Sado. In quella stessa area più a destra, come nella foto, è presente un altro lago: *Inawashiro*. Anche la forma della porzione di terra è la stessa di quella del tweet. Questa è la risposta corretta alla quarta domanda.



Lago Inawashiro e isola di Sado

Questo passaggio è stato un esempio concreto di come un'ipotesi iniziale plausibile possa essere corretta valutando dettagli importanti, invece che fermarsi ad un'osservazione superficiale.

L'ultima domanda della Task 6 e anche l'ultima della Room, chiede quale sia la città che l'aggressore considera probabilmente casa propria. Con tutti gli indizi raccolti, in particolare, il riferimento a Hirosaki, la risposta è proprio: *Hirosaki*.

Cosa ho imparato:

Questa task mi ha fatto capire che in OSINT, raramente esiste una prova unica e definitiva e quindi un'analista deve essere in grado di mettere insieme più indizi indipendenti che permettono di formulare l'ipotesi più ragionevole.

CONCLUSIONE

Percorrere la Sakura Room, task per task, fermandomi a capire ogni concetto tecnico incontrato lungo il percorso - dai metadati SVG alla cronologia immutabile di GitHub, dal formato delle transazione Ethereum al funzionamento di WiGLE, fino al ragionamento necessario per orientarsi nel Dark Web - mi ha permesso di collegare competenze SOCMINT, tecniche di Blockchain Intelligence e di GEOINT, proprio come accadrebbe in un caso reale. Ma soprattutto mi ha permesso di capire molto di più sulla metodologia di indagine e il ciclo dell'intelligence che applicherò sicuramente durante i miei studi e i miei prossimi lavori.